

# Sistema de Banca por Internet · BP

Diseño de arquitectura de soluciones con el modelo C4

Septiembre 2026 · Nube: Microsoft Azure · Documento de 15 páginas  
José Luis León · joleonca@gmail.com

## Resumen ejecutivo

### El problema y por qué este proyecto

Hoy los clientes esperan resolver sus operaciones bancarias desde el celular o la computadora, a cualquier hora y sin ir a una agencia. BP necesita ofrecer ese servicio de forma segura, cumpliendo la norma y aprovechando los sistemas que ya tiene.

- **Servicio a cualquier hora.** El cliente consulta, transfiere y paga por su cuenta, sin filas ni horarios de agencia.
- **Cientes nuevos a distancia.** Abrir la cuenta desde el celular llega a más personas sin abrir más agencias.
- **Cumplimiento y confianza.** La norma exige avisar cada movimiento y guardar un registro confiable de lo que ocurre; un canal propio lo hace siempre de la misma forma.
- **Base para crecer.** Lo que se construye se reutiliza en nuevos productos, y la inversión aumenta solo si los clientes lo usan.

Beneficios cualitativos: sus cifras (ahorro por operación, altas nuevas) se definen con BP. El enunciado no describe el canal digital actual, por lo que esta sección debe validarse con el patrocinador.

### Necesidades del negocio y requisitos planteados

| Necesidad del negocio         | Qué se espera                                                                                       |
|-------------------------------|-----------------------------------------------------------------------------------------------------|
| Autoservicio seguro           | Consultar y mover el dinero por cuenta propia, a cualquier hora, con la seguridad de un banco.      |
| Cientes nuevos sin agencia    | Abrir una cuenta desde el celular con foto del rostro y cédula, con identidad verificada.           |
| Aprovechar lo que BP ya tiene | Usar la plataforma central, el sistema de datos adicionales y el servidor de inicio de sesión.      |
| Avisar cada movimiento        | Informar al cliente por al menos dos medios, como exige la norma.                                   |
| Trazabilidad y cumplimiento   | Registrar todo lo que hace el cliente y cumplir las normas de datos, seguridad y lavado de activos. |
| Servicio siempre disponible   | Que no se caiga, se recupere de un desastre y se vigile, con buena rapidez.                         |

### Qué se propone

**También se pide** agilidad para clientes frecuentes, integración ampliable, despliegue en la nube dentro de presupuesto, y este documento con diagramas y justificaciones.

Una plataforma de banca por internet con una aplicación web (SPA) y una aplicación móvil multiplataforma, construida como microservicios detrás de una capa de integración con API Gateway. Se integra con la plataforma Core y el sistema complementario de clientes, permite transferencias internas e interbancarias, notifica cada movimiento por SMS y correo, y deja un registro de auditoría inmutable. Los clientes nuevos abren su cuenta desde el móvil con reconocimiento facial y verificación de documento, con validaciones de KYC (conocimiento del cliente) y AML (prevención de lavado de activos) antes de aprobar la cuenta. El ingreso usa el servidor de autorización OAuth 2.0 de BP con el flujo Authorization Code y PKCE recomendado por el estándar. Además, cuenta con redundancia en varias zonas de disponibilidad de Azure y una región de recuperación ante desastres, incluyendo herramientas de observabilidad con métricas, trazas y registros centralizados (Azure Monitor y OpenTelemetry) que permitan detectar y alertar de forma temprana ante fallas o degradación del servicio.

### Decisiones clave (detalle técnico en las págs. 3 a 8)

| Tema              | Decisión                                                              | Por qué                                              |
|-------------------|-----------------------------------------------------------------------|------------------------------------------------------|
| Nube y regiones   | Azure: South Central US (3 zonas) y recuperación en North Central US  | Menor latencia medida desde Ecuador (103 y 104 ms)   |
| Web y móvil       | Angular con BFF para la web; Flutter para iOS y Android               | Tokens fuera del navegador; una base de código móvil |
| Autenticación     | Código de autorización con PKCE; llave del dispositivo con huella     | Estándar vigente; la biometría no sale del teléfono  |
| Integración       | API Gateway, microservicios y eventos en Azure Service Bus            | Desacople y tolerancia a fallas                      |
| Datos y auditoría | Una base por servicio; libro mayor de solo anexar y archivo inmutable | Autonomía y evidencia para el regulador              |
| Resiliencia       | Tres zonas y región de recuperación en espera                         | 99,95 %, RPO ≤ 5 min, RTO ≤ 1 h                      |

|                                    |                                    |                                 |                           |
|------------------------------------|------------------------------------|---------------------------------|---------------------------|
| 99,95 %<br>disponibilidad objetivo | ≤ 5 min<br>pérdida máxima de datos | ≤ 1 h<br>tiempo de recuperación | 103 ms<br>latencia medida |
|------------------------------------|------------------------------------|---------------------------------|---------------------------|

**Costo y plan.** Estimación con precios de lista de Azure: de US\$ 0,5 a 1,5 mil por mes en la etapa de prototipo y de US\$ 32 a 46 mil por mes con todo el diseño (unos US\$ 0,11 a 0,15 por usuario activo mensual, con 300 000 usuarios activos al mes). Más de la mitad son precios ya verificados; el resto (SMS, verificación de identidad, tráfico) son estimaciones por cotizar, y el costo de los SMS depende de cuántos movimientos generen un mensaje (pág. 12 y 13).

**Cómo leer este documento.** Pág. 2: alcance. Pág. 3 a 8: diagramas. Pág. 9 a 13: procesos y temas transversales. Pág. 14 y 15: decisiones.

## Alcance, procesos de negocio y supuestos

| Proceso de negocio                          | Qué logra el cliente o el banco                                                              | Decisiones     |
|---------------------------------------------|----------------------------------------------------------------------------------------------|----------------|
| <b>Onboarding</b>                           | Abrir una cuenta desde el móvil con cédula, selfie en vivo y código dactilar                 | D5, D6, D19    |
| <b>Autenticación</b> (Web SPA y Mobile App) | Ingresar de forma segura con huella o con usuario y clave más segundo factor                 | D2, D3, D4, D6 |
| <b>Consulta de datos y movimientos</b>      | Ver saldos e histórico de movimientos, con respuesta rápida incluso para clientes frecuentes | D8, D12, D13   |
| <b>Transferencias internas</b>              | Mover dinero entre sus propias cuentas al instante                                           | D10            |
| <b>Transferencias interbancarias</b>        | Enviar dinero a otros bancos con estados claros y sin pagos duplicados                       | D10, D14       |
| <b>Auditoría</b>                            | Registro inmutable de cada acción, útil para reguladores y disputas                          | D11            |
| <b>Notificaciones</b>                       | Aviso de cada movimiento por SMS y correo, como exige la norma                               | D9, D14        |

Transversales: seguridad (OWASP, WAF), regulaciones (protección de datos), resiliencia y monitoreo, costos y plan de entregas. Los pagos entre cuentas propias e interbancarias se tratan dentro de las transferencias.

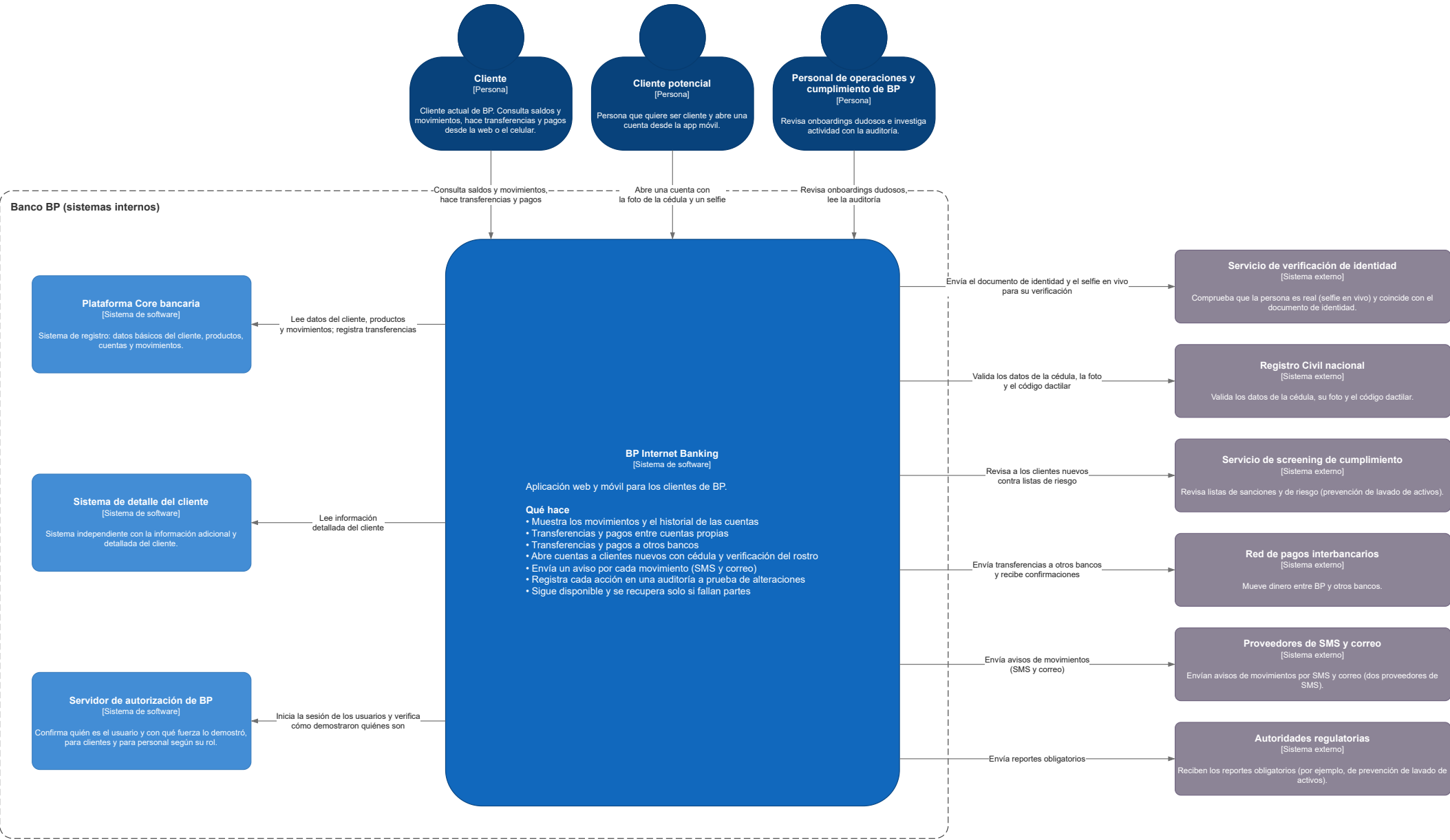
### Índice de requisitos y decisiones

| Requisito                                                                                                         | Dónde                      |
|-------------------------------------------------------------------------------------------------------------------|----------------------------|
| Datos del Core y de un sistema complementario; capa de integración con API Gateway y los tres servicios iniciales | Pág. 4 y 10 (D7, D8, D12)  |
| Al menos dos sistemas de notificación                                                                             | Pág. 11 (D14)              |
| SPA y app móvil multiplataforma, con dos opciones y justificación                                                 | Pág. 9 y 14 (D2, D3)       |
| OAuth 2.0 y mejor flujo de autenticación; método de ingreso tras el onboarding                                    | Pág. 9 (D4, D6)            |
| Onboarding con reconocimiento facial dentro del flujo de autorización                                             | Pág. 6 y 9 (D5)            |
| Base de auditoría y persistencia para clientes frecuentes con patrones de diseño                                  | Pág. 7, 10 y 11 (D11, D12) |
| Normativa financiera y de datos personales                                                                        | Pág. 12 (D19)              |
| Alta disponibilidad, tolerancia a fallas, DR, seguridad, monitoreo, auto-reparación, baja latencia                | Pág. 8 y 12 (D15 a D17)    |
| Nube (Azure o AWS) y presupuesto                                                                                  | Pág. 8 y 12 (D1, D18)      |
| Arquitectura desacoplada y reutilizable; modelo C4 hasta componentes; decisiones justificadas                     | Pág. 3 a 7 y 14 a 15       |

### Supuestos

- **País y regulación:** Ecuador. No hay región de nube local, por eso se midió la latencia y se justifican las regiones (pág. 8). El alojamiento fuera del país es una transferencia internacional de datos personales que exige consentimiento, cláusulas contractuales y registro; **debe confirmarse con Legal** (pág. 12).
- **Tamaño:** banco mediano: 1 millón de clientes, **300 000 usuarios activos al mes**, 60 000 por día, 40 000 transferencias por día ( $\approx$  1,2 millones de movimientos al mes) y pico de 5 transferencias por segundo.
- **Sistemas de BP:** el Core expone REST; el Core, el sistema de detalle y el servidor de autorización están en un centro de datos de BP conectado por circuito privado (ubicación por confirmar). El servidor OAuth 2.0 (clientes y personal, por rol) soporta PKCE y aprovisionamiento por API.
- **Fuera de alcance:** tarjetas y pagos con tarjeta. Notificaciones push: diferidas a una etapa posterior.
- **Metas de calidad:** disponibilidad 99,95 %,  $RPO \leq 5$  min,  $RTO \leq 1$  h, lectura p95 menor a 500 ms dentro de la región más la latencia de red ( $\approx$  103 ms).
- **Precios y leyes:** los precios son de lista y las normas citadas se resumen de fuentes públicas; ambos requieren profundizar el análisis.

C4 nivel 1 · Contexto del sistema



**Cómo leerlo.** Las personas (azul oscuro) usan BP Internet Banking (azul intenso). El sistema se apoya en tres sistemas internos de BP (Core, detalle del cliente y servidor de autorización) y en seis servicios externos: verificación de identidad, registro civil, screening de sanciones, red interbancaria, proveedores de SMS y correo, y autoridades. Cada flecha dice para qué se usa. No hay tecnología en este nivel a propósito.

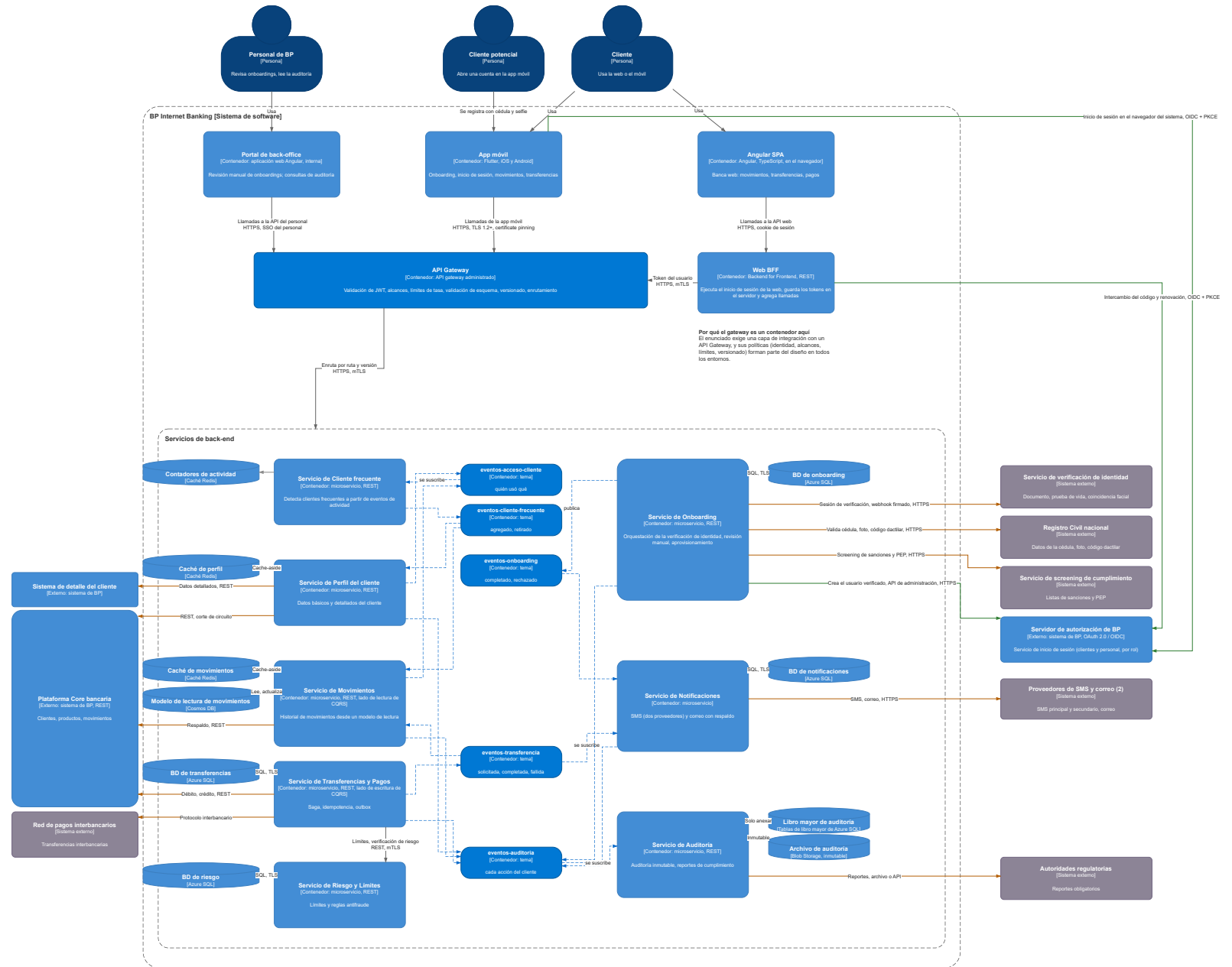
## C4 nivel 2 · Contenedores (vista lógica)

**Cómo leerlo.** La SPA (a través del BFF) y la app móvil entran por el API Gateway, incluido aquí porque el enunciado lo exige como capa de integración. Ocho microservicios tienen cada uno su almacén de datos (base por servicio).

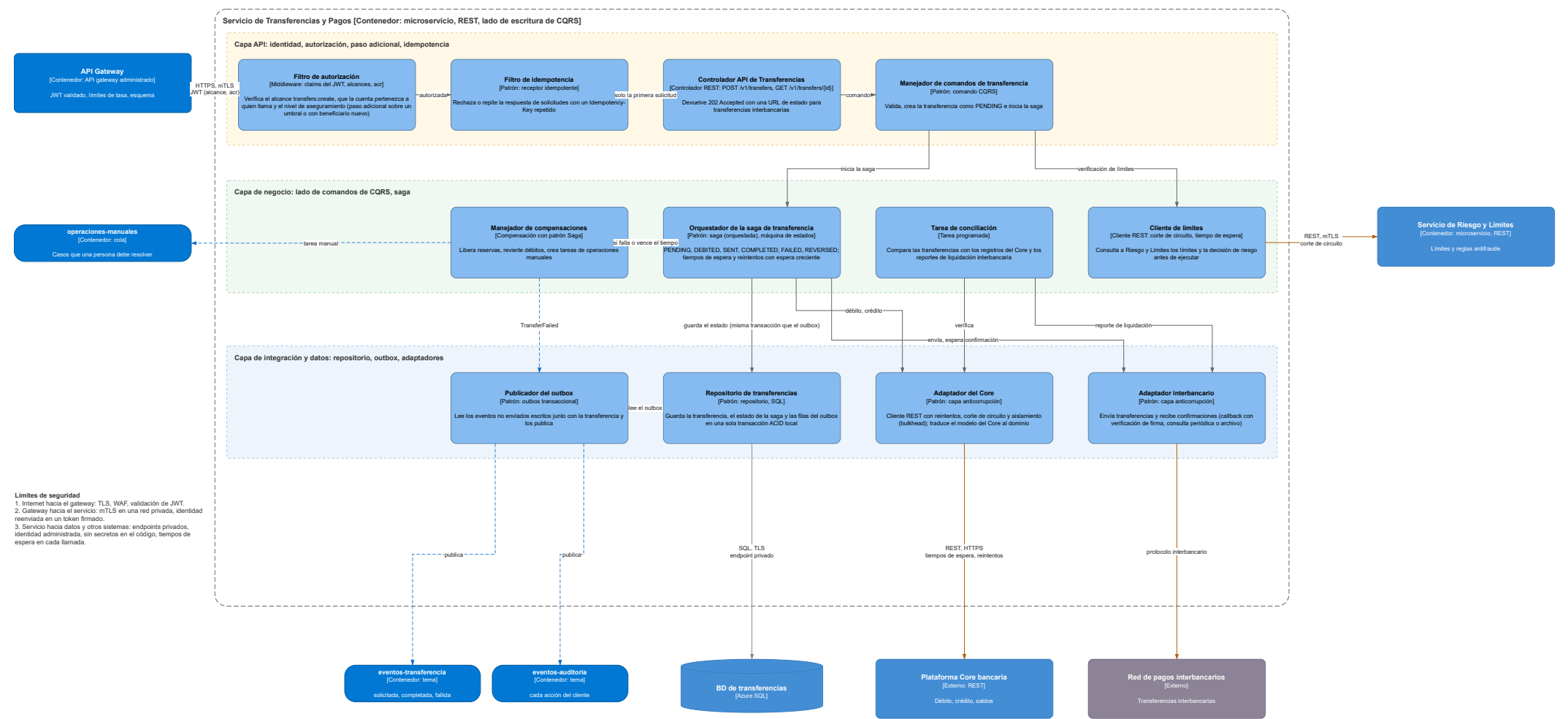
Los eventos viajan por temas de Service Bus (cápsulas azules, línea punteada): quien publica no conoce a quien escucha.

**Colores:** azul oscuro, personas; azul, contenedores y sistemas de BP; azul intenso, componentes gestionados de Azure; gris violeta, sistemas externos. Línea gris: llamada síncrona; punteada azul: evento; naranja: sistema externo; verde: autenticación.

Regiones, zonas, borde y clústeres no se mezclan aquí: están en el diagrama de despliegue (pág. 8).

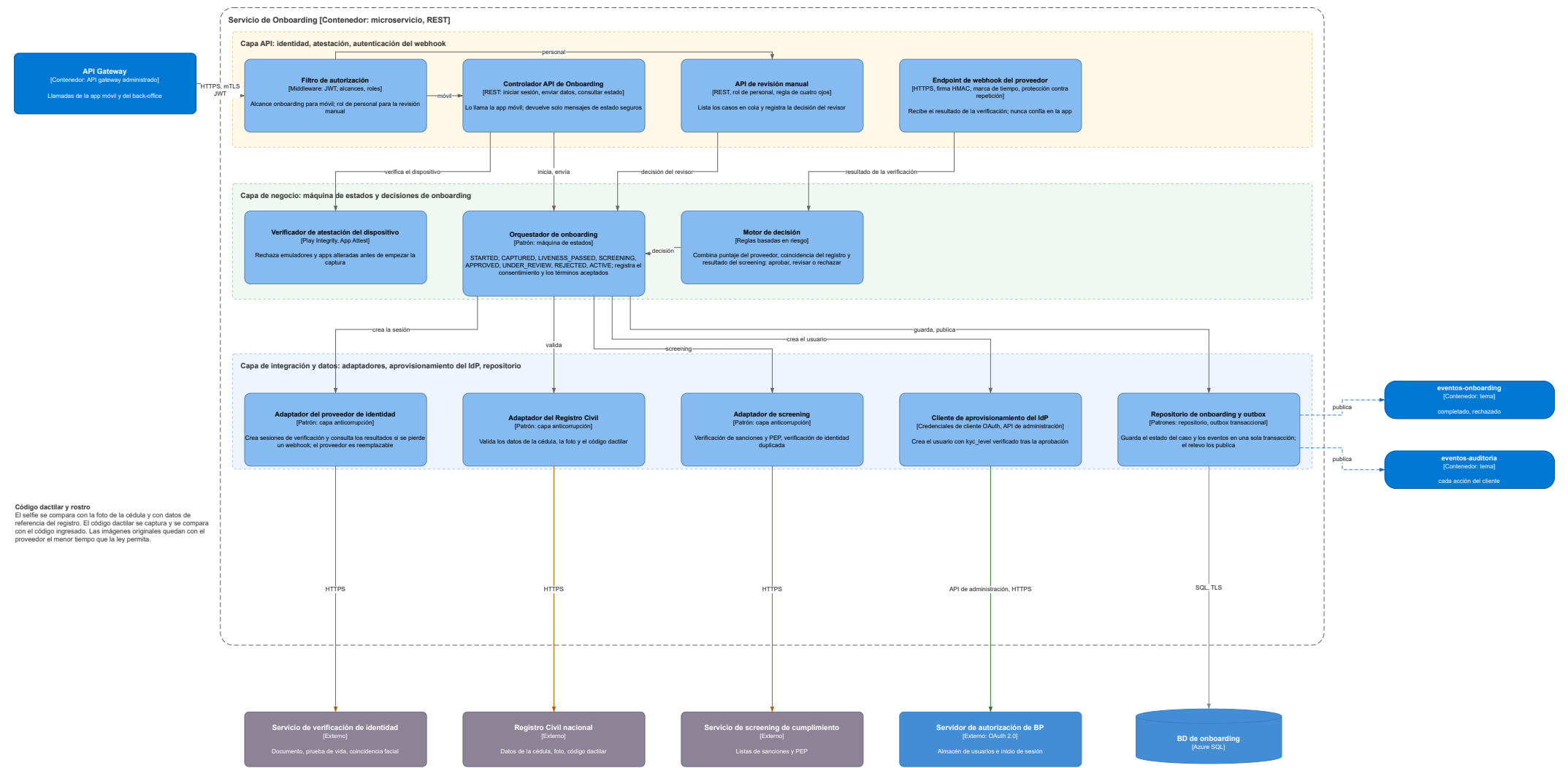


C4 nivel 3 · Componentes: Servicio de Transferencias y Pagos



**Cómo leerlo.** Tres capas. **API:** filtro de autorización (alcance y nivel de aseguramiento, con paso adicional para montos altos o beneficiarios nuevos) e idempotencia. **Negocio:** saga orquestada con compensaciones y conciliación. **Integración y datos:** repositorio con *outbox* transaccional y adaptadores anti-corrupción hacia el Core y la red interbancaria, con reintentos, corte de circuito y aislamiento. Seguridad: JWT validado en el gateway, mTLS entre servicios, endpoints privados y sin secretos en el código.

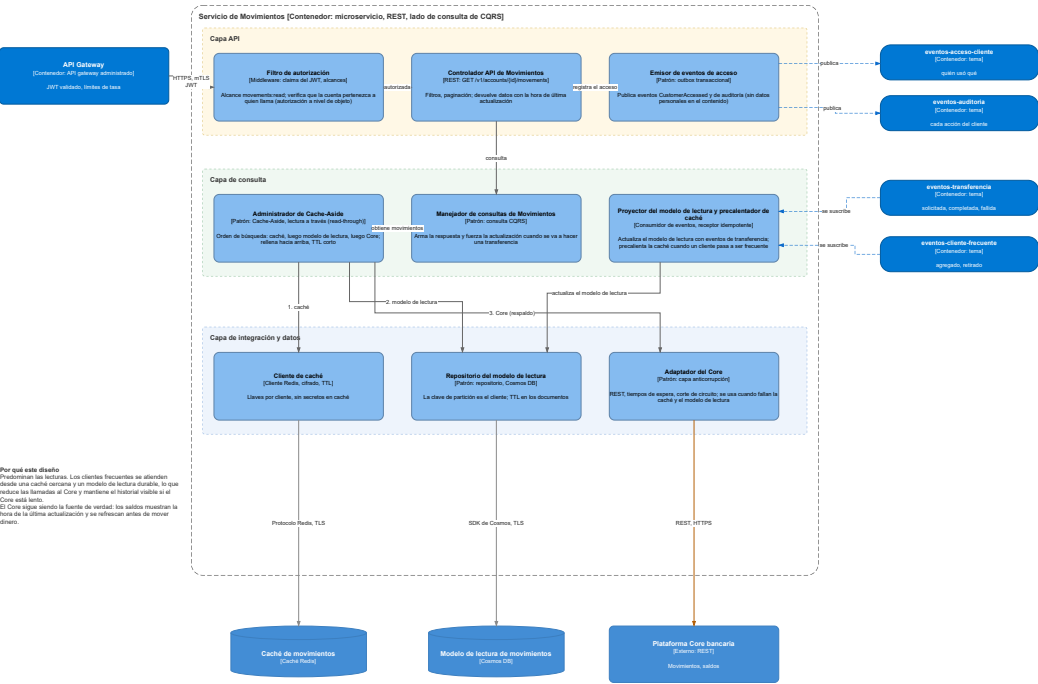
C4 nivel 3 · Componentes: Servicio de Onboarding



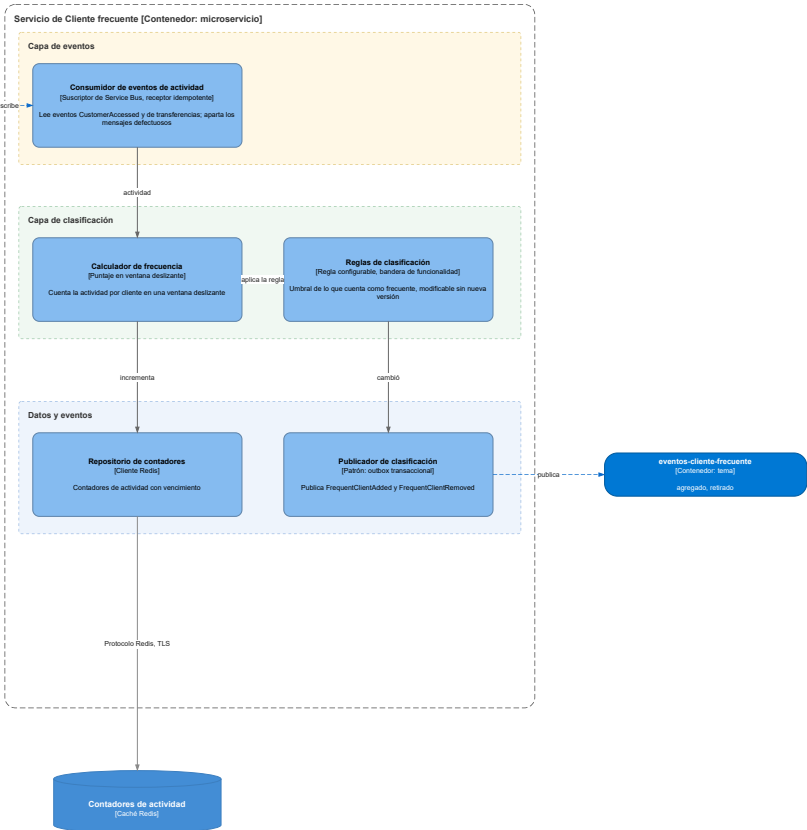
**Cómo leerlo.** El resultado de la verificación nunca se confía a la app: llega por un webhook firmado del proveedor y se combina con la validación del registro civil (foto y código dactilar) y el screening de sanciones. Una máquina de estados decide aprobar, revisar o rechazar; si se aprueba, el cliente se crea en el servidor de autorización con nivel de identidad verificado. La atestación del dispositivo bloquea emuladores y apps alteradas antes de capturar datos.

C4 nivel 3 · Componentes: Movimientos y Cliente frecuente

Servicio de Movimientos (lectura)

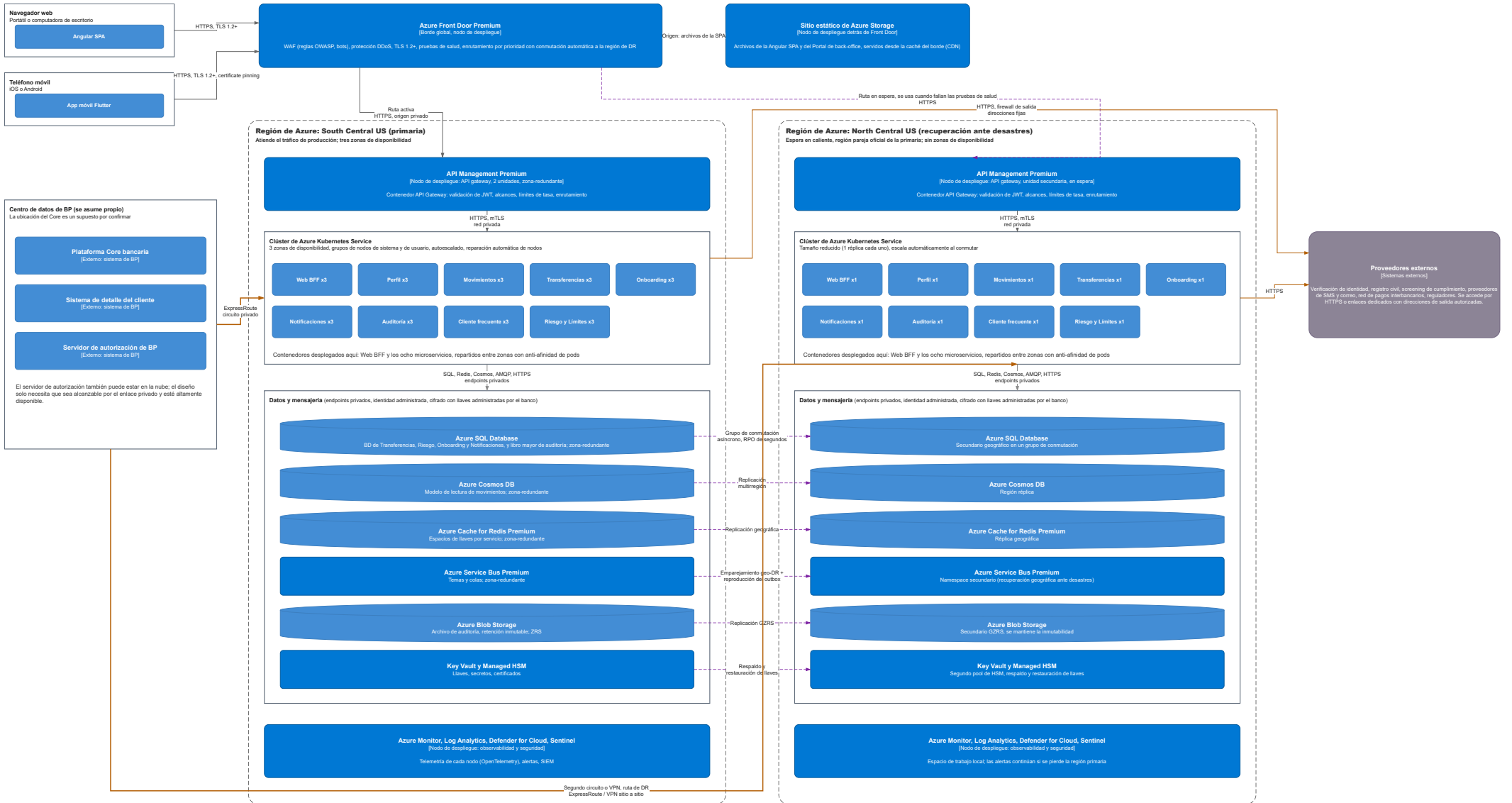


Servicio de Cliente frecuente



**Cómo leerlo.** Mecanismo de persistencia para clientes frecuentes con patrones: *Cache-Aside* (caché, luego modelo de lectura, luego Core), *CQRS* de lectura con vista materializada en Cosmos DB y clasificación por eventos. El Servicio de Cliente frecuente solo cuenta actividad y anuncia cambios; el de Movimientos actualiza su propio modelo y precalienta su caché. El Core sigue siendo la fuente de verdad.

## Despliegue e infraestructura · Alta disponibilidad y recuperación ante desastres



**Cómo leerlo.** Front Door con WAF protege el borde y conmuta hacia la región de recuperación si fallan las pruebas de salud. La región primaria usa tres zonas de disponibilidad (gateway, clúster de contenedores y datos zona-redundantes). North Central US, su pareja oficial, recibe replicación continua (SQL con grupo de conmutación, Cosmos DB, Redis, Service Bus, almacenamiento inmutable, llaves) y funciona como espera en caliente. Esa región no ofrece zonas: es un riesgo aceptado y documentado (pág. 13). Supuesto: el Core está en un centro de datos de BP conectado por ExpressRoute con VPN de respaldo.

# Procesos: Onboarding y Autenticación

## Onboarding (D5, D6)

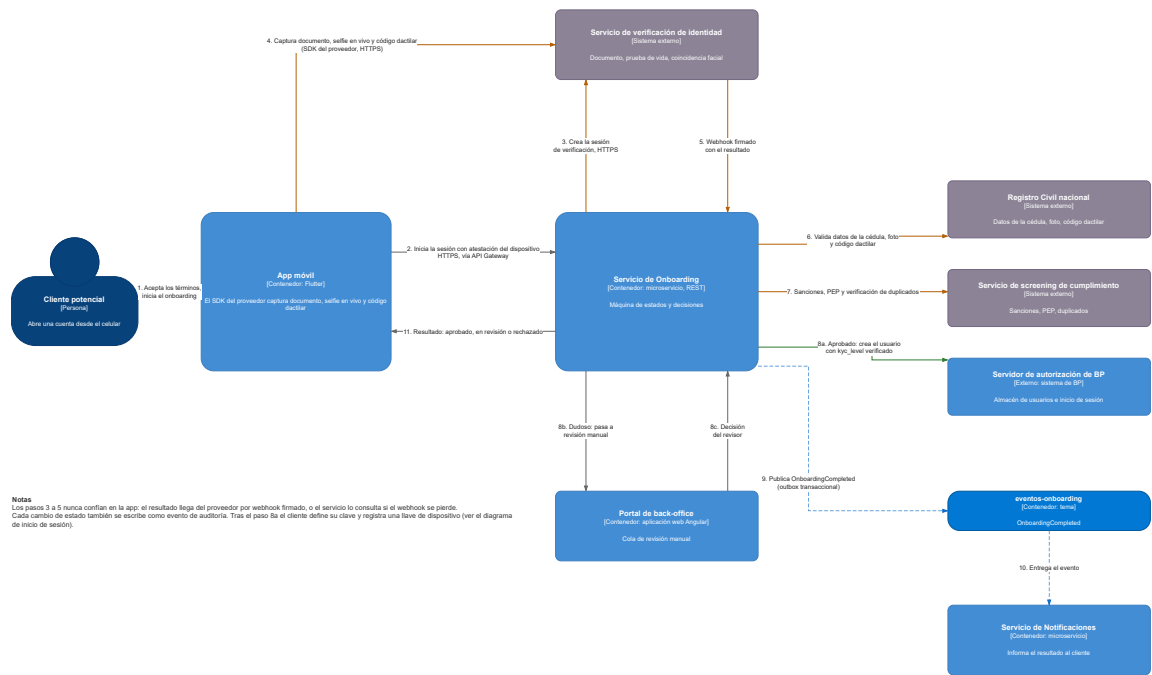
El cliente nuevo abre su cuenta desde el móvil con la cédula, un selfie en vivo y su código dactilar. Un proveedor especializado comprueba que es una persona real y que coincide con el documento. Aporta rapidez sin ir a una agencia y la evidencia de identidad que piden las normas contra el lavado de activos.

- 1. El cliente acepta términos y consentimiento; la app prueba que el dispositivo es legítimo (atestación).
- 2. El Servicio de Onboarding crea una sesión de verificación; el SDK del proveedor captura documento, selfie con prueba de vida y código dactilar.
- 3. El proveedor responde con un webhook firmado. Nada se acepta de la app.
- 4. Se valida con el registro civil (datos, foto, código dactilar) y con listas de sanciones y duplicados.
- 5. Aprobado: se crea el usuario en el servidor de autorización con nivel de identidad verificado. Dudoso: cola de revisión manual. Rechazado: mensaje seguro y reintentos limitados.
- 6. El cliente define su clave y registra su dispositivo. Los primeros días tienen límites reducidos.

| Flujo evaluado                         | Veredicto                | Motivo                                                                                                                  |
|----------------------------------------|--------------------------|-------------------------------------------------------------------------------------------------------------------------|
| Código de autorización + PKCE          | Elegido                  | Práctica actual para clientes públicos; evita la interceptación del código; el usuario nunca escribe su clave en la app |
| Implicito                              | Descartado               | Tokens visibles en la URL y el historial; retirado en OAuth 2.1                                                         |
| Contraseña del propietario del recurso | Descartado               | La app manejaría la clave; rompe MFA y controles de riesgo                                                              |
| Credenciales de cliente                | Solo servicio a servicio | No hay usuario involucrado                                                                                              |

| Acción del cliente                                         | Aseguramiento requerido                                                                             |
|------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| Ver saldos y movimientos; transferir entre cuentas propias | Llave del dispositivo con huella                                                                    |
| Transferir a un beneficiario registrado bajo el umbral     | Llave del dispositivo con huella                                                                    |
| Monto sobre el umbral o beneficiario nuevo                 | Llave del dispositivo más segundo factor (OTP de app) y periodo de espera para beneficiarios nuevos |
| Cambiar dispositivo, clave o contacto; recuperar cuenta    | Clave más OTP y reverificación facial con prueba de vida; alerta al cliente                         |

**Flutter frente a React Native (D3).** Flutter: interfaz y rendimiento idénticos en iOS y Android, buen soporte de almacenamiento seguro, biometría y pinning, una sola base de código. React Native queda como alternativa válida si el equipo es de JavaScript. Diagrama dinámico del inicio de sesión: en el repositorio.



**Diagrama dinámico del onboarding:** pasos numerados en orden; el resultado del proveedor llega por webhook firmado.

# Procesos: Consulta de datos y Transferencias

## Consulta de datos y movimientos (D8, D12, D13)

El cliente ve saldos y movimientos rápido, incluso con 100 ms de red hacia la nube. Los clientes que más usan la app reciben una experiencia aún más ágil porque sus datos recientes ya están preparados.

Los servicios de **Perfil** y **Movimientos** leen el Core y, cuando hace falta detalle, el sistema complementario, siempre a través de adaptadores que aíslan a BP de sus cambios. Para los **clientes frecuentes** se combinan cuatro patrones (pág. 7):

- **Clasificador por eventos:** cuenta la actividad y anuncia cuándo un cliente pasa a ser frecuente. La regla (por ejemplo, sesiones en 30 días) es configurable.
- **Modelo de lectura:** vista materializada de los últimos días en Cosmos DB, propiedad del servicio de Movimientos.
- **Cache-Aside:** consulta primero Redis, luego el modelo de lectura y por último el Core.
- **Precaentamiento:** al anunciarse el cambio o iniciar sesión, el primer pantallazo ya está listo.

El Core es siempre la fuente de verdad: se muestra la hora de la última actualización y se refresca antes de mover dinero. Si el Core está lento, los clientes frecuentes siguen viendo su historial reciente.

## Transferencias internas (D10)

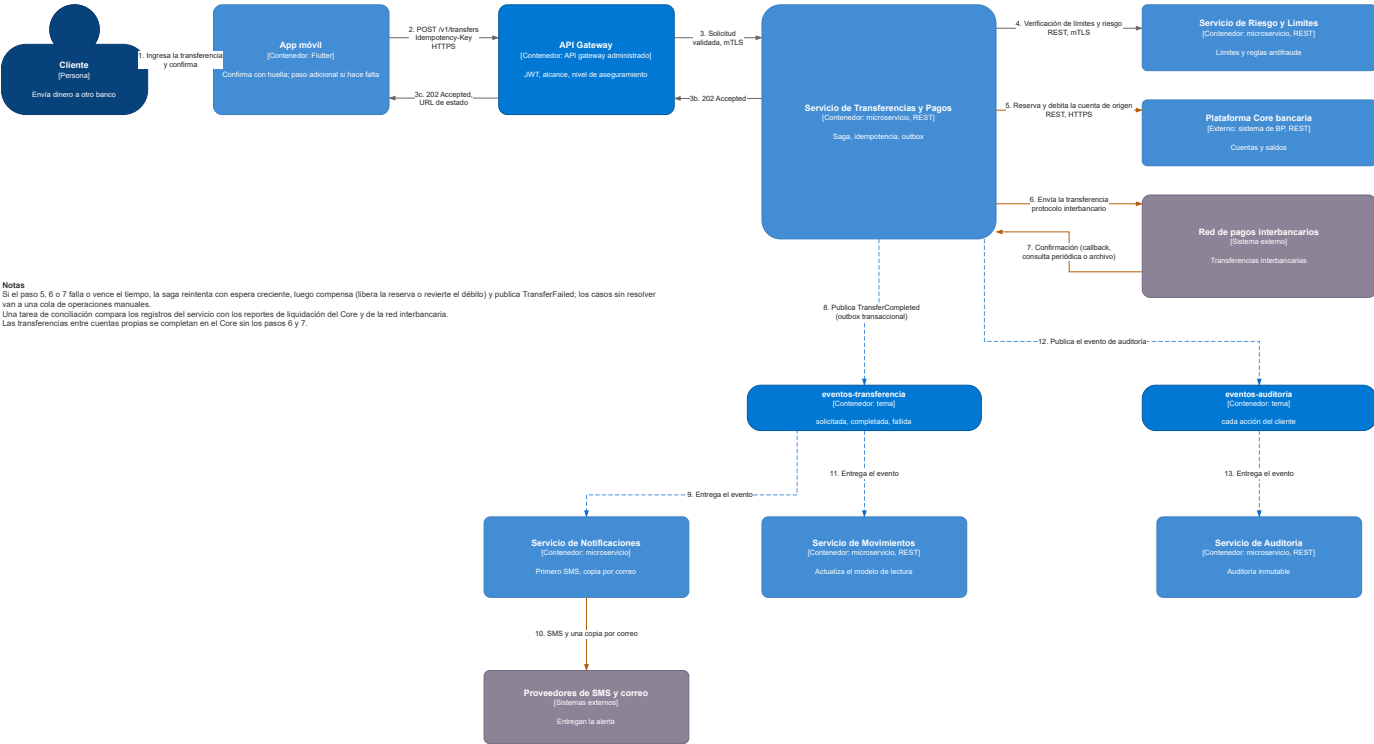
Entre cuentas propias, dentro del Core: validación de límites, débito y crédito y evento. Es una variante corta de la transferencia interbancaria: se completa de forma síncrona y no toca la red interbancaria.

## Transferencias interbancarias (D10)

Una transferencia toca varios sistemas. Si algo falla a medias, el dinero no puede perderse ni duplicarse; el cliente ve un estado honesto (pendiente, completada, fallida) en lugar de esperar sin saber.

- La app envía la orden con una **clave de idempotencia**: tocar dos veces no envía dos veces. Se exige un paso adicional para montos altos o beneficiarios nuevos.
- El servicio guarda la orden como pendiente y el evento en la misma transacción local (**outbox**) y responde 202 con una dirección de estado.
- Una **saga orquestada** reserva y debita en el Core, envía a la red interbancaria y espera la confirmación. Ante fallas o vencimientos reintenta con espera creciente y luego compensa (libera la reserva o revierte el débito).
- Una **conciliación** programada compara con el Core y los reportes de liquidación; los casos sin resolver van a una cola de operaciones manuales.
- Los eventos alimentan notificaciones, el modelo de lectura y la auditoría.

**Por qué una saga y no una transacción distribuida:** el Core y la red externa no admiten transacciones compartidas, y bloquear entre sistemas reduce la disponibilidad.



**Diagrama dinámico de la transferencia interbancaria:** pasos numerados en orden; el paso 5 y siguientes se omiten en una transferencia entre cuentas propias.

## Auditoría (D11)

Cada acción del cliente queda registrada de forma que nadie, ni un administrador, pueda alterarla. Ante un regulador, un fraude o una disputa hay una respuesta confiable, y el registro no hace más lento al cliente.

Cada servicio emite eventos de auditoría (quién, qué, cuándo, canal, resultado) mediante *outbox* hacia el tema **eventos-auditoria**. El Servicio de Auditoría los valida y los escribe en **tablas de libro mayor** de Azure SQL (solo anexar, con verificación criptográfica) y en un **archivo inmutable** con resúmenes firmados. La consulta es de solo lectura, por rol, y cada consulta queda auditada. Los campos sensibles se minimizan para conciliar inmutabilidad con la ley de datos personales.

No se usa Event Sourcing completo: el Core es la fuente de verdad de los saldos y añadiría complejidad sin beneficio proporcional. Puede revisarse si el banco quiere historial de dominio reproducible.

## Seguridad (D16)

| Capa                   | Controles                                                                                                                                                                                                                                                                                                                                         |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| OWASP                  | Top 10 web y API Security Top 10: autorización a nivel de objeto en cada servicio, límites de tasa, validación de esquema OpenAPI, protección XSS de Angular con CSP estricta, defensa CSRF. <b>ASVS</b> para web y API y <b>MASVS</b> para el móvil (pinning de certificados, detección de root y depuración, atestación de la app, ofuscación). |
| WAF y borde            | Azure Front Door con WAF (reglas OWASP, control de bots y de tasa), protección DDoS, TLS 1.2 o superior.                                                                                                                                                                                                                                          |
| Identidad              | OAuth 2.0 con PKCE, MFA y paso adicional por riesgo, tokens de vida corta con rotación, llave de dispositivo. Personal: acceso con Entra ID, acceso administrativo justo a tiempo.                                                                                                                                                                |
| Red y cargas           | Redes privadas, endpoints privados a bases de datos, mTLS entre servicios, identidades administradas, imágenes firmadas y escaneadas, sin IP públicas en servicios.                                                                                                                                                                               |
| Datos y llaves         | Cifrado en reposo con llaves administradas por el banco (Managed HSM), tokenización de números sensibles, secretos en Key Vault.                                                                                                                                                                                                                  |
| Antifraude y respuesta | Límites por monto y velocidad, espera para beneficiarios nuevos, alertas al cliente; ciclo de desarrollo seguro (modelado de amenazas, SAST, DAST, dependencias, pruebas de penetración); Defender y Sentinel para detección y respuesta a incidentes.                                                                                            |

## Notificaciones (D9, D14)

La norma exige avisar cada movimiento. El Servicio de Notificaciones lee los eventos de transferencia y de onboarding mediante **su propia suscripción de Azure Service Bus, que actúa como su cola de solicitudes**: si el servicio o un proveedor cae, los mensajes esperan y se reintentan; los que fallan repetidamente van a una cola de mensajes fallidos y se alerta a operaciones.

- **Canales:** SMS con dos proveedores (conmutación por falla con corte de circuito) y correo electrónico, con patrón Strategy y cadena de respaldo. Push queda diferido.
- Deduplicación por identificador de evento, mensajes con datos enmascarados (últimos 4 dígitos) y sin códigos de un solo uso.
- Costo: el SMS se cobra por mensaje; las reglas de canal las acuerdan Producto y Cumplimiento.

# Regulaciones, Resiliencia y monitoreo, Costos

## Regulaciones y cumplimiento (D19)

**Importante:** resumen a partir de fuentes públicas; los textos vigentes deben confirmarse con Legal y Cumplimiento antes de la entrega definitiva.

| Norma                                                                                                                   | Qué exige                                                                                                                                                                                  | Cómo responde el diseño                                                                                                                                                                                                                                                                |
|-------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Ley Orgánica de Protección de Datos Personales (LOPDP)                                                                  | Consentimiento, finalidad, minimización, seguridad, derechos del titular, cuidado de datos sensibles (biometría), notificación de brechas, condiciones para la transferencia internacional | Consentimiento registrado; datos mínimos y tokenizados; llaves del banco; proceso para solicitudes de titulares (seudonimización frente a la auditoría inmutable); cláusulas, consentimiento y registro para alojamiento y proveedores en el exterior; delegado de protección de datos |
| Ley Orgánica para el Fortalecimiento de la Ciberseguridad (publicada el 22 de mayo de 2026, según la fuente consultada) | Marcos de ciberseguridad, mitigación de amenazas, respuesta y reporte de incidentes                                                                                                        | Seguridad por capas, monitoreo continuo, plan de respuesta a incidentes con aviso al regulador, pruebas de penetración y simulacros de DR                                                                                                                                              |
| Superintendencia de Bancos, resolución SB-2021-2126 (riesgo operativo)                                                  | Monitoreo continuo de seguridad de TI, alta disponibilidad, recuperación ante desastres y continuidad                                                                                      | Objetivo 99,95 %, tres zonas más región de recuperación, RPO y RTO definidos, simulacros, observabilidad con SLO                                                                                                                                                                       |
| Codificación de la Junta de Política y Regulación Financiera                                                            | Estabilidad y requisitos técnicos, incluida la gestión de terceros y de la nube                                                                                                            | Debida diligencia del proveedor (SOC 2, ISO 27001), derechos de auditoría, plan de salida, diseño portable, registro de riesgos de terceros                                                                                                                                            |
| Prevención de lavado de activos (UAFE) y KYC                                                                            | Conocer al cliente, conservar registros, monitorear y reportar                                                                                                                             | Verificación de identidad con documento y prueba de vida, auditoría inmutable, reportes por umbral y patrón                                                                                                                                                                            |

## Resiliencia y monitoreo (D15, D17)

**Alta disponibilidad.** Tres zonas en la región primaria: gateway, clúster con nodos en zonas y datos zona-redundantes. Un fallo de un centro de datos no dispara conmutación regional.

**Recuperación.** Espera en caliente en North Central US con replicación continua y cómputo reducido que sube al conmutar; conmutación decidida por el comandante de incidentes según un manual, para evitar conmutaciones por errores transitorios; simulacros al menos dos veces al año.

**Tolerancia a fallas.** Tiempos de espera en cada llamada, reintentos con espera creciente solo en operaciones idempotentes, corte de circuito, aislamiento entre dependencias, límites de tasa, degradación elegante (historial en caché si el Core falla) y consumidores idempotentes.

**Auto-reparación.** Pruebas de vida y preparación, reemplazo automático de nodos, escalado por carga y por cola, infraestructura como código y despliegues con reversión automática.

**Monitoreo.** Instrumentación OpenTelemetry hacia Azure Monitor y Application Insights: registros, métricas y trazas correlacionadas de extremo a extremo; indicadores de negocio (éxito de transferencias, entrega de notificaciones, embudo de onboarding); alertas por consumo del presupuesto de errores de los SLO; pruebas sintéticas desde fuera; paneles y manuales de operación.

## Costos (D18)

| Componente                                         | Configuración supuesta                                                               | Estado     | US\$ por mes    |
|----------------------------------------------------|--------------------------------------------------------------------------------------|------------|-----------------|
| API Management Premium                             | 3 unidades (2 primaria y 1 DR) a US\$ 2 795                                          | Verificado | 8 385           |
| Cómputo de contenedores                            | 9 nodos a US\$ 168 y 2 clústeres a US\$ 73                                           | Verificado | 1 657           |
| Azure SQL Business Critical                        | 8 vCore × 2 réplicas y almacenamiento                                                | Verificado | ≈ 4 390         |
| Cosmos DB, Redis, Service Bus                      | 10 000 RU/s en 2 regiones; Redis P1 × 2; Service Bus × 2                             | Verificado | ≈ 3 400 a 4 000 |
| Managed HSM                                        | 1 pool por región a US\$ 2 336                                                       | Verificado | 4 672           |
| Front Door y tráfico                               | Base US\$ 330 y ≈ 3 TB de salida al mes                                              | Parcial    | 580 a 1 000     |
| Observabilidad y seguridad                         | 20 GB/día de registros, 5 GB/día a Sentinel, Defender                                | Parcial    | 3 200 a 4 300   |
| Almacenamiento, respaldos y tráfico entre regiones | Archivo inmutable, respaldos, replicación                                            | Parcial    | 500 a 1 500     |
| Verificación de identidad                          | ≈ 3 000 altas al mes × US\$ 1 a 2 (supuesto)                                         | Estimado   | 3 000 a 6 000   |
| SMS y correo                                       | ≈ 15 % de los movimientos por SMS × US\$ 0,03 (supuesto)                             | Estimado   | 3 000 a 9 000   |
| Total aproximado                                   | Precios de lista, ±30 %, sin personal; ≈ US\$ 0,11 a 0,15 por usuario activo mensual |            | 32 000 a 46 000 |

Precios unitarios verificados en la API pública de precios de Azure (South Central US, 19 y 20 de septiembre de 2026). **Verificado:** precio unitario comprobado. **Parcial:** precio comprobado con volumen supuesto. **Estimado:** no está en la API y requiere cotización. **Los SMS son el costo más sensible:** enviar un SMS por cada movimiento (≈ 1,2 millones al mes) sumaría unos US\$ 30 mil al mes; la regla de canales se cierra con Producto y Cumplimiento. Cada precio y su consulta están en cost-validation.md del repositorio. Palancas: reservas de 1 a 3 años, SQL de propósito general en lugar de Business Critical, DR mínimo, caché que reduce llamadas al Core, reglas que limitan el SMS y muestreo de registros.

## Plan de entregas y evolución

Esta arquitectura es el destino. No se construye entera antes de que el primer cliente la vea: se llega en cuatro etapas y cada una debe probar algo antes de pagar la siguiente. El gasto y el riesgo crecen junto con la demanda comprobada (D20).

| Etapa                  |  | Técnica ágil y de prototipado                                                                                                                                                        | Alcance                                                                                                                                                                                                                         | Costo indicativo (US\$/mes)                 |
|------------------------|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------|
| 1. Prototipo           |  | <i>Fake Door</i> (botón de transferencias que mide intención y responde «próximamente»), <i>Pinocchio</i> (app navegable), <i>Mechanical Turk</i> (personal hace a mano la revisión) | App y SPA sobre el gateway hacia endpoints simulados generados desde los contratos OpenAPI; verificación de identidad en el entorno de pruebas del proveedor; banderas de funcionalidad y analítica. Sin Core, sin datos reales | 0,5 a 1,5 mil                               |
| 2. MVP de solo lectura |  | Producto mínimo viable: valor real con bajo riesgo                                                                                                                                   | Perfil y Movimientos con arquitectura hexagonal (dominio aislado del adaptador del Core); integración real con Core y servidor de autorización; auditoría básica; contenedores en un clúster pequeño                            | 3 a 6 mil                                   |
| 3. Transaccional       |  | Expansión iterativa: primero cuentas propias, luego interbancarias, por cohortes y con banderas                                                                                      | Transferencias (saga, idempotencia, outbox), Riesgo y Límites, Notificaciones (SMS y correo), Auditoría, Service Bus, onboarding real, paso adicional de autenticación                                                          | 15 a 23 mil (incluye proveedores variables) |
| 4. Escala empresarial  |  | Endurecimiento según carga medida y exigencias del regulador                                                                                                                         | Multirregión con Front Door, DR en espera con simulacros, datos zona-redundantes, Cliente frecuente con Cosmos DB y Redis, auto-reparación avanzada, canal push opcional para reducir el SMS                                    | 32 a 46 mil                                 |

### Puertas de decisión (hipótesis «al menos X % de Y hará Z»; umbrales de ejemplo por ajustar con Producto)

| Puerta      | Hipótesis                                                                                                                                  | Si falla                                                         |
|-------------|--------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| Fin etapa 1 | ≥ 70 % de los usuarios piloto completa el ingreso y el onboarding sin ayuda; ≥ 25 % toca el botón de transferencias en dos semanas         | Cambiar el flujo o las funciones; no construir la integración    |
| Fin etapa 2 | ≥ 40 % del piloto entra cada semana a ver saldo o movimientos; p95 de lectura dentro del objetivo; sin incidentes graves en cuatro semanas | Corregir experiencia o rendimiento antes de agregar funciones    |
| Fin etapa 3 | ≥ 15 % de los activos completa una transferencia en el primer mes; éxito ≥ 99,5 %; entrega de notificaciones ≥ 99 %                        | Mantener las transferencias con bandera y arreglar la fiabilidad |
| Fin etapa 4 | SLO 99,95 % durante dos meses seguidos; simulacro de DR dentro de RTO y RPO                                                                | Seguir endureciendo antes de ampliar la comunicación             |

### Umbral mínimo de resiliencia y deuda técnica aceptada

**Umbral mínimo.** La etapa 1 no maneja datos reales. La etapa 2 exige una sola región zona-redundante, respaldos con restauración probada e infraestructura como código para construir el DR bajo demanda. **Antes de abrir transferencias más allá del piloto (etapa 3) hace falta DR en espera y un primer simulacro, o una aceptación de riesgo firmada por Riesgo y Cumplimiento.** La auditoría se mantiene con outbox y libro mayor, sin Event Sourcing.

| Deuda aceptada                                     | Se paga cuando                                        |
|----------------------------------------------------|-------------------------------------------------------|
| Endpoints simulados (etapa 1)                      | La etapa 2 los reemplaza y se eliminan                |
| Publicador de eventos en proceso (etapa 2)         | La etapa 3 incorpora Service Bus tras el mismo puerto |
| Región única con restauración (etapa 2)            | DR en espera antes de abrir transferencias            |
| Sin modelo de clientes frecuentes hasta la etapa 4 | Las mediciones muestran lentitud del Core             |
| Sin canal push                                     | El costo del SMS o el uso lo justifican               |
| DR sin zonas de disponibilidad                     | Microsoft habilita zonas o se usa la región alterna   |

Contratos primero (OpenAPI), enrutamiento por ruta o cohorte en el gateway y arquitectura hexagonal hacen que una maqueta y un servicio real sean intercambiables, sin reescribir clientes. Una prueba de intención en un banco debe ser honesta («próximamente, cuéntanos si lo quieres») y revisada por Legal y Cumplimiento.

## Alternativas evaluadas y descartadas (1 de 2)

Cada decisión tiene al menos dos justificaciones teóricas y las opciones comparadas. El detalle completo de contexto, compromisos y alternativas está en el registro de decisiones del repositorio.

| #   | Decisión               | Elegido                                                                                                              | Justificación 1                                                                                      | Justificación 2                                                                                   | Alternativas descartadas                                                                                                |
|-----|------------------------|----------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| D1  | Nube y regiones        | Azure: South Central US (primaria, 3 zonas) y North Central US (DR, pareja oficial)                                  | Latencia medida desde Ecuador de 103 y 104 ms; misma experiencia tras conmutar                       | Servicios gestionados de identidad, HA y seguridad; la pareja oficial simplifica la replicación   | AWS (equivalente sin ventaja clara); Brasil Sur (181 ms); este y oeste de EE. UU. (DR a 133 ms); centro de datos propio |
| D2  | SPA web                | Angular con BFF, estáticos en CDN                                                                                    | Estructura única para varios equipos y seguridad integrada (XSS, CSP, XSRF)                          | El BFF mantiene los tokens en el servidor: sin robo por XSS; entrega estática barata y resiliente | React (menos estructura), Vue (ecosistema bancario menor), renderizado en servidor (sin sentido tras un login)          |
| D3  | App móvil              | Flutter                                                                                                              | Rendimiento y apariencia idénticos en iOS y Android, sin puente JavaScript                           | Una base de código y buen soporte de almacenamiento seguro, biometría y pinning                   | React Native (alternativa si el equipo es de JavaScript); nativo (doble costo)                                          |
| D4  | Flujo de autenticación | Código de autorización con PKCE (S256) para web (vía BFF) y móvil                                                    | Práctica vigente del estándar (OAuth 2.0 Security BCP y 2.1); protege ante interceptación del código | Las credenciales no pasan por la app; MFA y riesgo se centralizan en el servidor de autorización  | Implícito; contraseña del propietario; credenciales de cliente solo entre servicios                                     |
| D5  | Onboarding facial      | Proveedor SaaS tras un adaptador, orquestado por el Servicio de Onboarding                                           | Evidencia KYC/AML (documento, vida, rostro) con certificaciones y defensa actual contra deepfakes    | El adaptador permite cambiar de proveedor sin tocar la autenticación                              | Servicios solo de rostro (Azure Face, Rekognition); modelos propios (riesgo y costo)                                    |
| D6  | Ingreso posterior      | Llave de dispositivo con huella (passkey), clave más OTP de respaldo, paso adicional por riesgo                      | La biometría no sale del teléfono; resistente al phishing                                            | Ingreso rápido y menos restablecimientos de clave                                                 | Rostro en cada ingreso; solo OTP por SMS (SIM swap); token físico                                                       |
| D7  | Capa de integración    | Front Door con WAF, API Management y BFF web                                                                         | Un solo punto de seguridad, límites y versionado antes del código de negocio                         | Servicios privados con mTLS; se agregan servicios sin cambiar las apps                            | Kong autogestionado; solo Application Gateway; sin gateway                                                              |
| D8  | Servicios              | Microservicios por capacidad: los 3 obligatorios más Notificación, Auditoría, Cliente frecuente, Onboarding y Riesgo | Aislamiento de fallas y escalado independiente                                                       | Extensible: nuevos productos consumen los mismos eventos, gateway e identidad                     | Monolito modular; solo 3 servicios; funciones por acción                                                                |
| D9  | Comunicación           | REST/HTTPS síncrono para consultas; eventos asíncronos en Service Bus (AMQP)                                         | Desacople en el tiempo, reintentos y cola de fallidos                                                | Semántica bancaria: duplicados, sesiones, transacciones                                           | GraphQL o gRPC en el borde; Event Hubs; RabbitMQ autogestionado                                                         |
| D10 | Transferencias         | Saga orquestada con idempotencia, outbox y conciliación                                                              | El Core y la red no admiten transacción distribuida                                                  | Reintentos seguros: sin pagos dobles ni eventos perdidos                                          | 2PC o XA; saga coreografiada; llamada síncrona con reintento                                                            |

## Alternativas evaluadas y descartadas (2 de 2)

| #   | Decisión            | Elegido                                                                       | Justificación 1                                                                     | Justificación 2                                                                          | Alternativas descartadas                                   |
|-----|---------------------|-------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|------------------------------------------------------------|
| D11 | Auditoría           | Eventos por outbox a libro mayor SQL (solo anexar) y archivo inmutable        | Inmutable y verificable sin la complejidad de Event Sourcing global                 | Sin impacto en la latencia; separación de funciones y acceso auditado                    | Event Sourcing completo; logs como auditoría; CDC por base |
| D12 | Clientes frecuentes | Cache-Aside (Redis), modelo de lectura (Cosmos DB) y clasificador por eventos | Menos llamadas al Core sobre una latencia de red de ≈ 103 ms                        | Degradación elegante si el Core falla; el clasificador solo cubre a quienes lo necesitan | Solo caché con TTL; replicar todo el Core                  |
| D13 | Acceso a datos      | Base por servicio: SQL, Cosmos DB, Redis, Blob                                | Autonomía y aislamiento de fallas                                                   | Almacén adecuado a cada carga; acceso privado y llaves del banco                         | Base compartida; un único NoSQL                            |
| D14 | Notificaciones      | SMS (2 proveedores) y correo con Strategy y respaldo; push diferido           | Canales y proveedores redundantes: la notificación regulatoria es difícil de perder | Desacople por eventos; extensible a push sin cambiar el resto                            | Push como principal (diferido); pasarela SMS propia        |
| D15 | HA y DR             | Región primaria con 3 zonas y espera en caliente en la pareja oficial         | Las zonas resisten la caída de un centro de datos sin latencia extra                | RPO ≤ 5 min y RTO ≤ 1 h con costo moderado                                               | Una sola región; activo-activo; respaldo en frío           |
| D16 | Seguridad           | Defensa en profundidad y confianza cero                                       | Capas independientes: WAF, identidad, red privada, cifrado con llaves propias       | Referencias reconocidas (OWASP ASVS y MASVS, ISO 27001)                                  | Solo seguridad de perímetro; secretos en configuración     |
| D17 | Observabilidad      | OpenTelemetry hacia Azure Monitor y Application Insights, con SLO             | Trazas correlacionadas para diagnosticar rápido entre muchos servicios              | Instrumentación neutral al proveedor                                                     | Prometheus y ELK autogestionados; APM de terceros          |
| D18 | Costos              | Estimación por componente con precios verificados y palancas de ahorro        | El gasto se liga al valor de la resiliencia                                         | Los servicios gestionados reducen la operación                                           | Hardware propio; no estimar                                |
| D19 | Cumplimiento        | Matriz norma a control con responsables de temas abiertos                     | Trazabilidad ante el regulador                                                      | Consentimiento, llaves del banco y minimización de datos                                 | Híbrido con datos en el país si Legal lo exige             |
| D20 | Entrega             | Cuatro etapas con pretotipado y puertas de decisión                           | Evidencia antes de invertir                                                         | El costo crece con la demanda                                                            | Entrega única; prototipo y reescritura                     |

### Riesgos y supuestos por validar

| Riesgo o supuesto                                                                                                       | Mitigación                                                                                               | Responsable                   |
|-------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|-------------------------------|
| Alojar datos personales fuera de Ecuador (transferencia internacional)                                                  | Cláusulas, consentimiento, registro y llaves propias; alternativa híbrida con datos sensibles en el país | Legal, Delegado de datos      |
| Ubicación y protocolo reales del Core; disponibilidad del circuito privado                                              | Adaptadores que aíslan el protocolo; confirmar en la etapa 2                                             | Arquitectura, Infraestructura |
| Capacidades del servidor de autorización (PKCE, PAR, passkeys, aprovisionamiento por API)                               | Alternativas documentadas: clave más OTP de app; controles compensatorios                                | Seguridad                     |
| SDK Flutter y cobertura de documentos ecuatorianos del proveedor de verificación; acceso al servicio del registro civil | Selección por criterios; proveedor alterno tras el adaptador; envoltorio nativo                          | Producto, Cumplimiento        |
| Entrega de SMS en Ecuador y su costo; precios de referencia                                                             | Pruebas por operador, agregador local, cotizaciones                                                      | Producto, Compras             |
| Región de recuperación sin zonas de disponibilidad                                                                      | Riesgo documentado; alternativa: este de EE. UU. como DR                                                 | Arquitectura                  |

**Repositorio público.** Contiene este PDF, el registro completo de decisiones (D1 a D20), la validación de costos línea por línea (cost-validation.md), los 14 diagramas C4 editables (.drawio) y en imagen, el plan de solución y este esquema. La dirección se indica en los comentarios de la entrega.

**Referencias.** Modelo C4 (c4model.com), OAuth 2.0 Security BCP y perfil FAPI 2.0, OWASP ASVS, MASVS y API Security Top 10, Azure Retail Prices API, normas ecuatorianas citadas en la pág. 12.